

1 OBJETIVO

Este laboratorio tiene como propósito que el estudiante comprenda las implicaciones de transmitir información en texto plano y explore mecanismos de cifrado aplicables a servicios inseguros como FTP y bases de datos.

Al finalizar la práctica, el estudiante estará en capacidad de:

- Analizar tráfico de red con **Wireshark** e identificar credenciales y datos transmitidos en texto plano.
- Implementar un esquema de **cifrado simétrico (AES)** en Python para proteger archivos transferidos vía FTP.
- Configurar cifrado en servicios (FTPS/SFTP y TLS en bases de datos) y validar su efectividad con capturas de red.
- Comparar dos enfoques de protección de datos y recomendar al cliente la mejor alternativa.

2 LECTURAS PREVIAS

- Presentaciones de clase.
- Documentación oficial de Wireshark: <https://www.wireshark.org/docs/>
- Documentación de PyCryptodome (librería AES en Python):
<https://pycryptodome.readthedocs.io>
- Documentación de Cryptography (librería de Python):
<https://cryptography.io/en/latest/installation/>
- Guía de SFTP: <https://www.hostinger.com/co/tutoriales/como-usar-sftp>
- Configuración de SSL/TLS en MySQL:
<https://dev.mysql.com/doc/refman/8.0/en/using-encrypted-connections.html>

3 INFORMACIÓN BÁSICA

En el laboratorio anterior, cada grupo entregó un informe con las vulnerabilidades detectadas en la infraestructura de la organización. A partir de este informe, la gerencia identificó que uno de los problemas más críticos está relacionado con el **cifrado**: tanto el servicio FTP como la base de datos transmiten información en texto plano.

Esto significa que credenciales, comandos y datos sensibles pueden ser interceptados con herramientas como Wireshark sin mayor dificultad. La organización expresó gran preocupación al respecto, pues entienden que si un atacante llegara a tener acceso a la red, la fuga de información sería inmediata y crítica para su operación.

Actualmente, la organización no tiene claridad sobre qué solución adoptar. Algunos miembros sugieren proteger directamente los archivos sensibles antes de transmitirlos, mientras que otros consideran más conveniente habilitar mecanismos de cifrado en los propios servicios. Ustedes, como equipo de consultores en ciberseguridad, han propuesto explorar ambas alternativas, implementarlas y posteriormente determinar cuál es la más adecuada para las necesidades del cliente.

Recursos disponibles

Cada grupo cuenta con acceso a:

- Un servidor FTP vulnerable.
- Un servidor de base de datos sin cifrado habilitado.
- Una máquina Kali con Wireshark y Python instalado.

Credenciales de acceso

Para la conexión como cliente al servicio FTP las credenciales son:

- Usuario: `ftpuser`
- Contraseña: `ftp123`

Para la conexión como cliente al servicio de DB las credenciales son:

- Usuario: `root`
- Contraseña: `root_password` (Solo si es caso tienda, de lo contrario no hay contraseña)
- Es importante saltar verificación de ssl con `ssl=0` en un principio.

Para la conexión como administrador vía **SSH** a los servidores **FTP** y de **base de datos** se han asignado las siguientes credenciales universales para todos los grupos:

- Usuario: **root**
- Contraseña: **password123!**

Dentro de los servicios tienen acceso root y apt disponible. Pueden instalar los paquetes que requieran.

Restricción de alcance

Prohibido salir del alcance. Solo deben analizar y modificar los servicios FTP y de base de datos de su infraestructura asignada. Está prohibido interceptar tráfico de otros grupos o redes externas.

Advertencias Adicionales (*Warning*)

Denegación Accidental de Servicios Durante las prácticas interactuarán directamente con la infraestructura del negocio desde la VM Kali provista. Si estas interacciones resultan en denegación de servicios existirán penalizaciones:

- **Apagado de HARDWARE:** Calificación inmediata de 0 en el laboratorio sin posibilidad de recuperación.
- **Apagado de VMs:** Penalización de 1 unidad en calificación del laboratorio.
- **Apagado de SERVICIOS:** No representará una penalización directa en la nota. Pero se insiste en la importancia de no atentar contra los sistemas que se están auditando.

Nota: Cualquier inconveniente presentado con la infraestructura deberá ser comunicado en horarios razonables al asistente graduado para su solución.

Restricciones Técnicas (*VPN, SSH y RDP*)

La VPN asignada a cada grupo presenta conflictos si es accedida por más de un usuario simultáneamente. Se recomienda organizarse bien para evitar esto.

4 PROCEDIMIENTO

El laboratorio está dividido en tres fases:

1. Captura de tráfico en texto plano:

- Conectarse al servidor FTP y transferir archivos.
- Realizar consultas simples en la base de datos.
- Analizar con Wireshark las credenciales y datos transmitidos.

2. Cifrado de archivos con Python y AES:

- Implementar un programa en Python que permita cifrar un archivo antes de subirlo al FTP y descifrarlo al descargarlo.
- Entregar el código junto con un README que explique cómo ejecutar el programa.

3. Cifrado de servicios:

- Configurar SFTP o FTPS en el servidor FTP.
- Habilitar conexiones cifradas (TLS/SSL) en la base de datos. (Si utilizan un certificado autofirmado, al conectarse como clientes deberán omitir la verificación de autenticidad con `-ssl-verify-cert=0`. Esto es aceptable en ambientes académicos, pero no es recomendado fuera de estos.)
- Capturar nuevamente con Wireshark y comprobar que tanto credenciales como datos están cifrados.
- Documentar el procedimiento paso a paso con capturas de pantalla (antes y después del cifrado).

5 TRABAJO PROPUESTO

Como consultores en ciberseguridad, los estudiantes deberán:

- Implementar ambas alternativas de cifrado solicitadas.
- Documentar el proceso y evidencias con capturas de Wireshark.
- Elaborar un análisis comparativo de pros y contras de cada solución.
- Redactar una recomendación final para la organización sobre cuál alternativa adoptar.

6 ENTREGABLES

- Archivo .zip con el código en Python, README detallado y capturas de wireshark.
- Informe técnico en PDF no-mayor a 20 páginas con:
 - Explicación de las capturas de tráfico.

- Paso a paso de configuración de FTPS/SFTP y TLS en la base de datos.
- Comparación entre las dos alternativas.
- Recomendación final para la organización.

7 EVALUACIÓN

Criterio	Valor
Código en Python con README (funcionalidad, claridad)	25 %
Informe técnico (explicación, evidencias, claridad)	35 %
Evidencias de Wireshark (antes y después)	20 %
Análisis comparativo y recomendación final	20 %
Total	100 %

8 HISTORIAL DE REVISIONES

Fecha	Autor(es)	Versión	Referencia de Cambios
25/08/2025	Juan Andrés Ariza	1.0	Versión inicial del laboratorio 2
26/01/2026	Julián Contreras	1.1	Aclaraciones

REVISOR(ES)

Nombre	Cargo	Institución
Carlos Lozano	Profesor Asistente del Departamento de Ingeniería de Sistemas y Computación	Universidad de los Andes
